

DigiWeb

Diagnostico de Seguridad Digital

OBJETIVO	FECHA	PREPARADO POR
revflowy.com	2026-04-28	DigiWeb Security

SCORE DE SEGURIDAD	70/100	MEDIO
--------------------	--------	-------

01. Resumen Ejecutivo

El sitio web revflowy.com cuenta con medidas de seguridad básicas implementadas, como el uso de protocolos de seguridad para la conexión a Internet y la protección contra ataques de cross-site scripting. Sin embargo, se han detectado algunos puntos débiles en la configuración de seguridad del sitio, como la falta de algunas cabezas de seguridad en las respuestas HTTP. En general, el sitio parece tener una seguridad decente, pero es importante realizar revisiones y actualizaciones periódicas para mantener la seguridad del sitio y proteger la información de los usuarios.

02. Puertos y Servicios

El sitio revflowy.com tiene varios puertos y servicios detectados. Los puertos abiertos son el 80, 443, 8080 y 8443, que corresponden a los servicios http, ssl/https, http-proxy y ssl/https-alt, respectivamente. Todos estos servicios están asociados con Cloudflare, lo que sugiere que el sitio utiliza Cloudflare como proveedor de servicios de seguridad y rendimiento en la web. Los puertos 80 y 443 son los más comunes para el tráfico web, mientras que los puertos 8080 y 8443 pueden ser utilizados para proxys o servicios de autenticación.

03. Analisis SSL/TLS

El certificado SSL/TLS del sitio revflowy.com no fue proporcionado en la información dada, pero se puede inferir que el sitio utiliza un certificado SSL/TLS válido, ya que se menciona que el protocolo utilizado es HTTPS y se establece una conexión segura. La versión de TLS utilizada no se especifica, pero se menciona que el servidor utilizó HTTP/2. El análisis de la herramienta testssl.sh solo informó un problema con la falta de soporte para GOST, lo que no es relevante para la mayoría de los usuarios.

04. Headers de Seguridad HTTP

El sitio revflowy.com tiene los siguientes headers de seguridad HTTP: - Strict-Transport-Security: este header establece una política de seguridad de transporte estricta, lo que significa que el sitio solo puede ser accedido a través de HTTPS. El valor es max-age=31536000, lo que significa que esta política es válida por un año. - X-Frame-Options: este header establece una política de opciones de marco, lo que evita que el sitio sea incluido en un marco de otro sitio. El valor es SAMEORIGIN, lo que significa que el sitio solo puede ser incluido en un marco del mismo origen. - X-XSS-Protection: este header establece una protección contra ataques de cross-site scripting (XSS). El valor es 1, lo que significa que la protección está activada, y mode=block, lo que significa que el navegador bloqueará cualquier ataque de XSS detectado. - Content-Security-Policy: este header establece una política de seguridad de contenido, lo que define qué fuentes de contenido son permitidas en el sitio. El valor es default-src 'self' https: data: 'unsafe-inline' 'unsafe-eval', lo que significa que el sitio permite contenido de sí mismo, HTTPS, datos y contenido inline y evaluado de forma no segura. - Permissions-Policy: este header establece una política de permisos, lo que define qué permisos son permitidos en el sitio. El valor es camera=(), microphone=(), geolocation=(), lo que significa que el sitio no permite el acceso a la cámara, el micrófono ni la geolocalización. - Referrer-Policy: este header establece una política de referentes, lo que define cómo se manejan los referentes en el sitio. El valor es no-referrer-when-downgrade, lo que significa que el sitio no enviará referentes cuando se accede a un sitio con una seguridad menor. Sin embargo, el sitio web carece de los siguientes headers de seguridad: - No hay un header de anti-clickjacking X-Frame-Options que especifique 'DENY', lo que podría permitir que el sitio sea incluido en un marco de otro sitio. - No hay un header de Content-Type-Options que especifique 'nosniff', lo que podría permitir que el navegador adivine el tipo de

05. Subdominios Detectados

No se encontraron subdominios. Por lo tanto, no hay riesgos asociados con subdominios.

06. Seguridad Email SPF/DMARC

La seguridad del email de revflowy.com se analiza a través de los protocolos SPF, DMARC y DKIM. A continuación, se presentan los resultados de la análisis: SPF: El registro SPF de revflowy.com es "v=spf1 include:_spf.mx.cloudflare.net ~all". Esto indica que el dominio utiliza el servicio de correo electrónico de Cloudflare y permite que los servidores de Cloudflare envíen correos electrónicos en su nombre. Sin embargo, el uso de ~all en lugar de -all puede ser un riesgo, ya que permite que los servidores no autorizados envíen correos electrónicos en nombre de revflowy.com, aunque con una menor prioridad. DMARC: El registro DMARC de revflowy.com es "v=DMARC1; p=none; rua=mailto:support@revflowy.com". Esto indica que el dominio tiene un registro DMARC, pero no está configurado para rechazar o cuarentena los correos electrónicos que no cumplan con los requisitos de autenticación. En su lugar, se envían informes de agregación a la dirección de correo electrónico support@revflowy.com. Esto puede ser un riesgo, ya que no se toman medidas para prevenir el phishing y el spoofing de correos electrónicos. DKIM: No se encontró información sobre la configuración de DKIM para revflowy.com. La falta de DKIM puede ser un riesgo, ya que no se puede garantizar la autenticidad de los correos electrónicos enviados en nombre de revflowy.com. En resumen, los riesgos identificados son: - El uso de ~all en el registro SPF puede permitir que los servidores no autorizados envíen correos electrónicos en nombre de revflowy.com. - La falta de configuración de DMARC para rechazar o cuarentena los correos electrónicos no autenticados puede permitir el phishing y el spoofing de correos electrónicos. - La falta de configuración de DKIM puede no garantizar la autenticidad de los correos electrónicos enviados en nombre de revflowy.com. Es

importante que se tomen medidas para mejorar la seguridad del email de revflowy.com, como configurar DMARC para re

07. Tecnologías Detectadas

A continuación, se presentan las tecnologías detectadas y sus posibles riesgos de seguridad: - cloudflare: - Riesgo de ataque de denegación de servicio (DoS) debido a la naturaleza de los servicios de seguridad en la nube. - Posibles problemas de privacidad debido a la recolección de datos por parte de Cloudflare. - HTTP/2: - Riesgo de ataques de inyección de datos debido a la complejidad de la implementación del protocolo. - Posibles problemas de compatibilidad con algunos navegadores y proxies. - SSL/TLS: - Riesgo de ataques de intermediario (Man-in-the-Middle) si el certificado no es válido o no es de confianza. - Posibles problemas de compatibilidad con algunos navegadores y sistemas operativos si no se soportan los protocolos más recientes. - HTML5: - Riesgo de ataques de inyección de código (Cross-Site Scripting, XSS) debido a la complejidad de la sintaxis y la semántica de HTML5. - Posibles problemas de compatibilidad con algunos navegadores y dispositivos si no se soportan las características de HTML5. - Meta-Author: - No representa un riesgo de seguridad directo, pero puede ser utilizado para identificar al autor del contenido y posibles vulnerabilidades en la implementación. - Open-Graph-Protocol: - Riesgo de ataques de inyección de metadatos si no se validan correctamente los datos proporcionados. - Posibles problemas de compatibilidad con algunos navegadores y plataformas si no se soportan los protocolos de metadatos. - Script: - Riesgo de ataques de inyección de código (Cross-Site Scripting, XSS) si no se validan correctamente los scripts ejecutados. - Posibles problemas de compatibilidad con algunos navegadores y dispositivos si no se soportan los lenguajes de scripting utilizados. - Strict-Transport-Security: - Riesgo de ataques de intermediario (Man-in-the-Middle) si no se configura correctamente la directiva HSTS. - Posibles problemas de compatibilidad con algunos navegadores y sistemas oper

08. Vulnerabilidades Web

Se encontró que el header anti-clickjacking X-Frame-Options no está presente en la respuesta HTTP. Esto puede permitir ataques de clickjacking, donde un atacante puede engañar a un usuario para que realice acciones no deseadas en la aplicación web. Además, se encontró un header no común llamado 'cf-ray' con contenido. Esto puede ser un indicador de que la aplicación web está utilizando Cloudflare, un proveedor de servicios de seguridad y rendimiento web. Sin embargo, la presencia de este header no necesariamente indica una vulnerabilidad, sino que puede ser un signo de la configuración de la aplicación web.

09. Riesgos Críticos

A continuación, se presentan los 5 riesgos críticos más importantes priorizados de mayor a menor: 1. Falta de soporte para GOST en el protocolo SSL/TLS: el análisis de SSL/TLS reveló que no se admite el protocolo GOST, lo que puede hacer que la conexión sea vulnerable a ataques de interceptación y descriptación. 2. Configuración insegura de HTTP: el servidor HTTP devuelve una respuesta 301 Moved Permanently sin especificar el protocolo de redireccionamiento seguro, lo que puede permitir a un atacante interceptar y modificar la solicitud. 3. Falta de autenticación y autorización adecuada: no se encontraron mecanismos de autenticación y autorización adecuados en el sitio web, lo que puede permitir a un atacante acceder a áreas restringidas del sitio. 4. Posibilidad de ataques de cross-site scripting (XSS): el análisis de Nikto reveló que el encabezado X-Frame-Options no está presente, lo

que puede permitir a un atacante realizar ataques de clickjacking y XSS. 5. Información de contacto y datos de registro de dominio inadecuados: el registro de dominio reveló que no hay información de contacto adecuada para el propietario del dominio, lo que puede dificultar la resolución de problemas de seguridad y la notificación de incidentes.

10. Recomendaciones Prioritarias

1. Configurar cabeceras de seguridad adicionales como Content-Security-Policy y X-Content-Type-Options para prevenir ataques de cross-site scripting (XSS) y cross-site request forgery (CSRF). 2. Activar la autenticación de dos factores para todos los usuarios y administradores del sitio para prevenir accesos no autorizados. 3. Realizar auditorías de seguridad regulares y pruebas de penetración para identificar vulnerabilidades y debilidades en el sitio. 4. Implementar un sistema de gestión de actualizaciones y parches para asegurarse de que el sitio y sus componentes estén actualizados con las últimas versiones de seguridad. 5. Utilizar un protocolo de cifrado más seguro como TLS 1.3 para proteger la comunicación entre el sitio y los usuarios. 6. Configurar el firewall para bloquear el tráfico no autorizado y restrictivo hacia el sitio, especialmente desde direcciones IP malintencionadas. 7. Establecer un sistema de monitoreo de seguridad para detectar y responder a incidentes de seguridad en tiempo real. 8. Utilizar una red de entrega de contenido (CDN) como Cloudflare para proteger el sitio contra ataques de denegación de servicio (DDoS) y mejorar la velocidad de carga del sitio. 9. Realizar copias de seguridad regulares del sitio y sus datos para garantizar la recuperación en caso de un incidente de seguridad o falla del sistema. 10. Capacitar a los desarrolladores y administradores del sitio sobre las mejores prácticas de seguridad y cómo implementarlas para prevenir vulnerabilidades y debilidades en el sitio.

11. Conclusion

El sitio revflowy.com cuenta con medidas de seguridad como el protocolo HTTPS y el encabezado Strict-Transport-Security, lo que indica que se prioriza la protección de la información de los usuarios. Sin embargo, se detectaron algunas vulnerabilidades y cabeceras no comunes, como la ausencia del encabezado X-Frame-Options en algunas respuestas, lo que podría ser un punto débil en la seguridad del sitio. En general, aunque se han implementado algunas medidas de seguridad, es importante que el sitio siga mejorando y actualizando sus medidas de protección para mantener la confianza de los usuarios y prevenir posibles ataques.

Terminos y Condiciones

Este reporte es un diagnostico informativo de seguridad. No constituye una auditoria completa ni un servicio de respuesta a incidentes. El analisis se limita al dominio autorizado por el cliente. DigiWeb no realiza pruebas de penetracion activas ni acceso a sistemas internos. Los hallazgos reflejan el estado del objetivo en la fecha de analisis. DigiWeb recomienda diagnosticos periodicos para mantener una postura de seguridad actualizada. El cliente declara haber autorizado expresamente este diagnostico.